

SSO Configuration Check

ServiceNow for Federal Instance

This report has been produced by TCS for DSG
Adversarial Testing

KPMG US

PPA - 918122

PTI - 918123

RP - 911907

SSO Configuration Check, Final

03/05/2026

This report is to assist with vulnerability remediation activities. This report does not carry an endorsement from the KPMG US Adversarial Testing Team.

This report is KPMG CONFIDENTIAL and for KPMG INTERNAL USE ONLY and its content cannot be shared or distributed in any form with a third-party client or vendor without initiating the client inquiry process.

Contents

- Executive Summary 1
 - Background and Scope 1
 - Summary of Findings 1
 - Assessment Details 2
 - Limitations 2
 - Additional Notes 2
- Detailed Findings..... 3
- Appendix 22
 - Risk Rating Criteria 23
 - Terminology 24
 - Methodology 25
 - DSG Disclaimer Notice 26

Assessment Overview

Timeline

Assessment Start Date	03/02/2026
Assessment Completion Date	03/05/2026
Report Completion	03/05/2026

Team

Name	Role	Email
Pranshu Raghav	Tester	pranshuraghav@kpmg.com
Paramita Das	Reviewer	paramitadas@kpmg.com

Report History

Name	Company	Date	Description
Pranshu Raghav	TCS	03/05/2026	Initial Report

Executive Summary

Background and Scope

As part of the Digital Security Group's (DSG) Adversarial Testing Program, TCS conducted a dynamic automated or manual SSO configuration check for ServiceNow for Federal Instance application.

The TCS team performed time bound security testing through manual methods. TCS has leveraged Burp Suite for conducting manual tests along with other open-source security testing software. The purpose of this SSO configuration check on the application was to identify the potential vulnerabilities.

The manual assessment encompassed the modules of Information gathering, Configuration management, Authentication testing, Authorization testing, session management, Input validation, and encryption to identify the security issues which could potentially affect the application.

The TCS team identified a total of 9 findings (from both automated and manual testing), which were categorized across various severity levels. No automated scans were performed for this SSO configuration check.

Summary of Findings

During this assessment, Nine (9) findings across all phases of testing were identified. Each finding has been classified into categories of **Very High**, **High**, **Medium**, **Low**, and **Informational** (0 Very High, 0 High, 0 Medium, 1 Low, 8 Informational) based on the risk level.

The table below details the findings discovered during the assessment. Each finding has been assigned a risk rating based on its potential impact to the firm and the likelihood of exploitation. These ratings provide a baseline for prioritization but should be evaluated within the broader context of the organization's security posture and existing compensating controls. The results of this assessment represent a point-in-time analysis of the application's security.

#	Finding	Dependency	Prior Test	Likelihood	Impact	Original Risk Rating	Updated Risk Rating
1	Application does not Redirect upon Session Expiration	Application		Low	Minor	Low	Low
2	Missing Content Security Policy Header	Microsoft		Low	Minor	Low	Informational
3	Misconfigured/Insecure Response Header	Microsoft		Low	Minor	Low	Informational
4	Missing X-Frame-Options Header	Microsoft		Low	Minor	Low	Informational
5	SAML - Weak Canonicalization Method Used	Microsoft		Low	Minor	Low	Informational

#	Finding	Dependency	Prior Test	Likelihood	Impact	Original Risk Rating	Updated Risk Rating
6	BREACH Vulnerability	Microsoft		Low	Minor	Low	Informational
7	Concurrent User Session	Application		Very Low	Negligible	Informational	Informational
8	Sensitive Information Disclosure	Application		Very Low	Negligible	Informational	Informational
9	CBC-mode Encryption Cipher Suites Supported in TLS	Application		Very Low	Negligible	Informational	Informational

Assessment Details

In addition to the findings summarized above, several assessment parameters provide context for the scope and configuration of the test. These details outline the environment, roles, and conditions under which the application was evaluated and should be considered when reviewing the overall results. The table below captures the key inputs and constraints of the assessment.

Field	Details
Test URL	https://shielddev.servicenowservices.com/navpage.do
Testing Environment	Pre-Production
Number of Access Level in Scope	1
User Roles	user1testad1@dev.uskgc.com testaduser2@dev.uskgc.com user3testad3@dev.uskgc.com
Scope of Test	SSO
Testing Window	03/02/2026 to 03/05/2026
Point of Contact (App Team)	Collier, Mick

Limitations

Additional Notes

Detailed Findings

Finding 1: Application does not Redirect upon Session Expiration

Low

Dependency: Application

Status: Open

Description:

During testing it was observed that when the user session expires in the Service Operation Workspace interface, the application displays a session expiration popup instead of immediately redirecting the user to the login page.

The message displayed is

Session expired (401)

Required to provide Auth information.

After closing the popup using the close button, the application reloads the same page instead of redirecting the user to the authentication page. This behavior appears to be related to the SPA architecture used by the ServiceNow workspace interface, where authentication is handled through background API requests rather than full page redirects.

No unauthorized access to data was observed after the session expired. The application still requires authentication to access protected resources.

Affected Systems & Locations:

<https://shielddev.servicenowservices.com/navpage.do>

Reproduction Steps:

1. Log in to the application as any valid user.
2. Navigate to the Service Operation Workspace.
3. Allow the session to expire.
4. Observe that the application displays the following popup.
5. Click the "X" button on the popup dialog.
6. Observe that the application reloads the same page rather than redirecting the user to the login page.

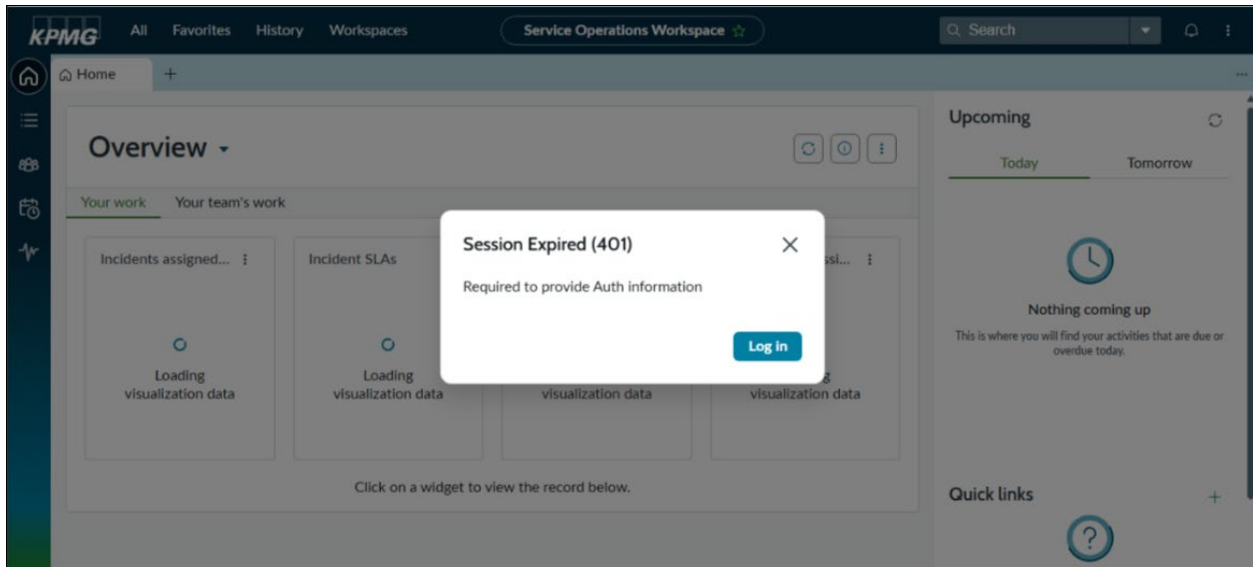


Figure 1

Remediation:

Consider automatically redirecting users to the login page once the session expires rather than allowing the interface to remain on the current page after the session expiration popup is closed. This may improve user experience and ensure clearer session state handling.

Closing/Downgrading Justification:

Finding 2 : Missing Content Security Policy Header

Informational

Dependency: Microsoft

Status: Open

Description:

During testing it was observed that the application does not implement a Content Security Policy (CSP)

header in its HTTP responses. Content Security Policy is a browser security mechanism that helps mitigate client-side attacks such as Cross-Site Scripting (XSS), data injection, and other malicious content execution by restricting the sources from which scripts, styles, images and other resources can be loaded.

In absence of the CSP header, the browser will accept resources from any origin permitted by default browser behavior. If another vulnerability such as Cross-Site Scripting exists, the lack of Content Security Policy could increase the impact of the attack by allowing malicious scripts to execute without restrictions.

Implementing a CSP header is considered a defense-in-depth security control that helps reduce the risk of client-side attacks.

Note: *The original severity of the finding is Low. However, it is being rated as Informational in this report. The finding is tracked in PPA-332020*

Affected Systems & Locations:

https://login.microsoftonline.us/f9724c3f-5875-41b3-b99a-b6eee358ee32/saml2?SAMLRequest=nVJba9swFP4rRu%2B%2B20ks4oCXMBZoO9NkfdibLB0nAllydWS3%2FfdznZR2DyujL0LoXL6b1sg6lfS0GtxZ38PjAOi8505ppJdKSQarqWEokWrWAVLH6aG6vaFJENHeGme4UcSrEME6afTWaBw6sAewo%2BTw6%2F6mJGfneqRhiGcJSggYA7xUtXm63jDgpgs1G3t2gkAY4u0mKIKz153vG5Q5SR10kluDpnVGK6khGDBsi2WS8bT189Uy97O4Sf2mKJjfLAAgzVfTkYSzJOJ9N5bDrLgkLVMLixNvvSnK42y4bwRoeFUUeQc5Fu8pTXjRtlUQQLeN4mt1jzRDICO%2BjiAPsNTqmXUmSKFn4UepH%2BTHKaZbRtAhWi8Vv4tVXr75JLaQ%2BfW5sc2IC%2BuN4rP365%2BE4LxilAHs3dX%2FR0wewOPs5YZDNevaDzgLsx9Q%2F58beoiab%2FyWxDj9CXYF7%2Bqpkv6uNkvzFq5QyT1sLzE3qnB1gDqpi7t9s4iCeX6Tw27mVQsekqoSwgEjCzRX37%2F%2B9%2BQM%3D&RelayState=43c92d3393d3fa50701bf79f68373c68&sso_reload=true

Reproduction Steps:

1. Login to the application and observe the Request/Response.
2. It is observed that CSP header is missing

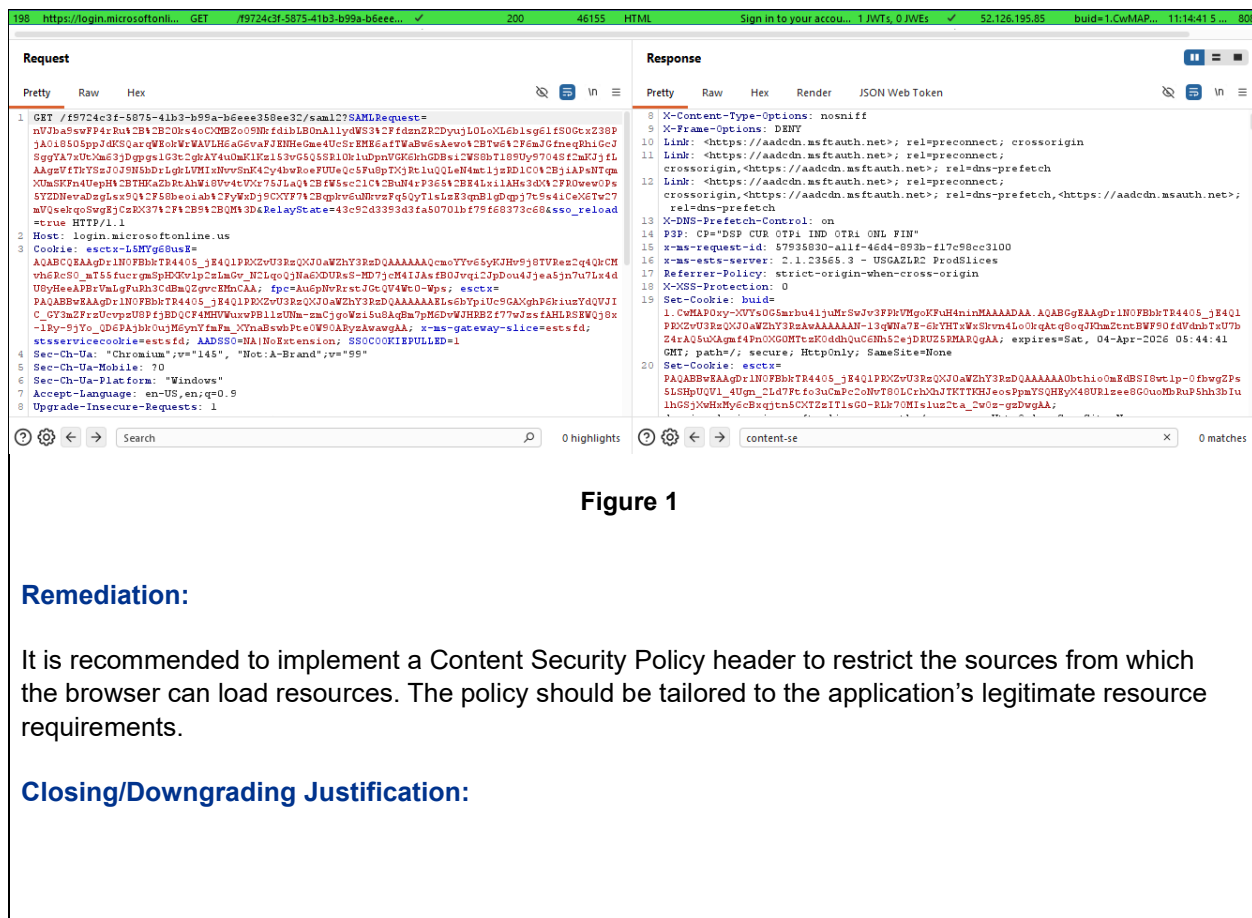


Figure 1

Remediation:

It is recommended to implement a Content Security Policy header to restrict the sources from which the browser can load resources. The policy should be tailored to the application's legitimate resource requirements.

Closing/Downgrading Justification:

Finding 3 : Misconfigured/Insecure Response Header

Informational

Dependency: Microsoft

Status: Open

Description:

During testing it was observed that the application response contains the HTTP security header.

X-XSS-Protection = 0

The X-XSS-Protection header controls the browser's built in cross site scripting (XSS) filter. Setting the value to 0 explicitly disables this protection mechanism in supported browser.

Note: *The original severity of the finding is Low. However, it is being rated as Informational in this report. The finding is tracked in PPA-332020*

Affected Systems & Locations:

https://login.microsoftonline.us/f9724c3f-5875-41b3-b99a-b6eee358ee32/saml2?SAMLRequest=nVJba9swFP4rRu%2B%2B20ks4oCXMBZoO9NkfdibLB0nAllydWS3%2FfdznZR2DyujL0LoXL6b1sg6lfS0GtxZ38PjAOi8505ppJdKSQargWEokWrWAVLH6aG6vaFJENHeGme4UcSrEME6afTWaBw6sAewo%2BTw6%2F6mJGfneqRhiGcJSggYA7xUtXm63jDgpgs1G3t2gkAY4u0mKIKz153vG5Q5SR10kluDpnVGK6khGDBsi2WS8bT189Uy97O4Sf2mKJjfLAAgzVfTkYSzJOJ9N5bDrLgkLVMIxNvvSnK42y4bwRoeFUUeQc5Fu8pTXjRtluQQLeN4mt1jzRDICO%2BjiAPsNTqmXUmSKFn4UepH%2BTHKaZbRtAhWi8Vv4tVXr75JLaQ%2BfW5sc2IC%2BuN4rP365%2BE4LxilAHs3dX%2FR0wewOPs5YZDNevaDzgLsx9Q%2F58beoiab%2FyWxDj9CXYF7%2Bqpkv6uNkvzFq5QyT1sLzE3qnB1gDqpj7t9s4iCeX6Tw27mVQsekqoSwgEjCzRX37%2F%2B9%2BQM%3D&RelayState=43c92d3393d3fa50701bf79f68373c68&sso_reload=true

Reproduction Steps:

1. Send a request to the application endpoint.
2. Inspect the HTTP response headers returned by the server.
3. Observe the presence of the following header:

X-XSS-Protection = 0

4. The value 0 disables the browser's XSS filtering mechanism.

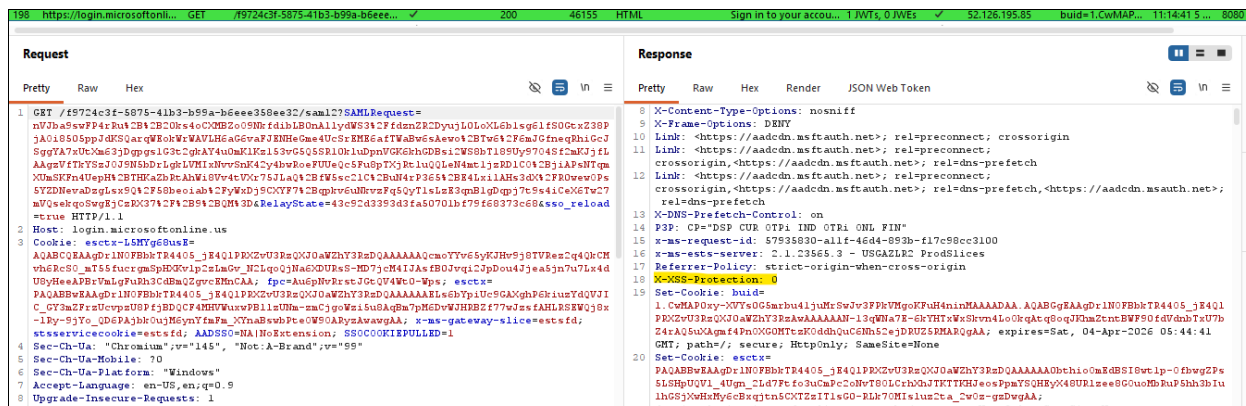


Figure 1

Remediation:

Set the value of the response header to X-XSS-Protection: 1; mode=block.

Closing/Downgrading Justification:

Finding 4 : Missing X-Frame-Options Header

Informational

Dependency: Microsoft

Status: Open

Description:

The response header has not enabled X-FRAME-OPTIONS, which helps prevents against Clickjacking attack. Clickjacking, also known as a 'UI redress attack', is when an attacker uses multiple transparent or opaque layers to trick a user into clicking on a button or link on another page when they were intending to click on the top-level page. Thus, the attacker is 'hijacking' clicks meant for their page and routing them to other another page, most likely owned by another application, domain, or both.

Note: *The original severity of the finding is Low. However, it is being rated as Informational in this report. The finding is tracked in PPA-332020*

Affected Systems & Locations:

https://login.microsoftonline.us/f9724c3f-5875-41b3-b99a-b6eee358ee32/saml2?SAMLRequest=nVJba9swFP4rRu%2B%2B20ks4oCXMBZoO9NkfdibLB0nAllydWS3%2FfdznZR2DyujL0LoXL6b1sg6lfS0GtxZ38PjAOi8505ppJdKSQarqWEokWrWAVLH6aG6vaFJENHeGme4UcSrEME6afTWaBw6sAewo%2BTw6%2F6mJGfneqRhiGcJSggYA7xUtXm63jDgpgs1G3t2gkAY4u0mKIKz153vG5Q5SR10kluDpnVGK6khGDBsi2WS8bT189Uy97O4Sf2mKJjflAAgzVfTkYSzJOJ9N5bDrLgkLVMIxNvvSnK42y4bwRoeFUeQc5Fu8pTXjRtluQQLen4mt1jzRDICO%2BjiAPsNTqmXUmSKFn4UepH%2BTHKaZbRtAhWi8Vv4tVXr75JLaQ%2BfW5sc2lC%2BuN4rP365%2BE4LxilAHs3dX%2FR0wewOPs5YZDNevaDzgLsx9Q%2F58beoiab%2FyWxDj9CXYF7%2Bqpkv6uNkvzFq5QyT1sLzE3qnB1gDqpj7t9s4iCeX6Tw27mVQsekqoSwgEjCzRX37%2F%2B9%2BQM%3D&RelayState=43c92d3393d3fa50701bf79f68373c68&sso_reload=true

Reproduction Steps:

1. Login to the application and observe the request/response.
2. It is observed that X-Frame-Options header is missing

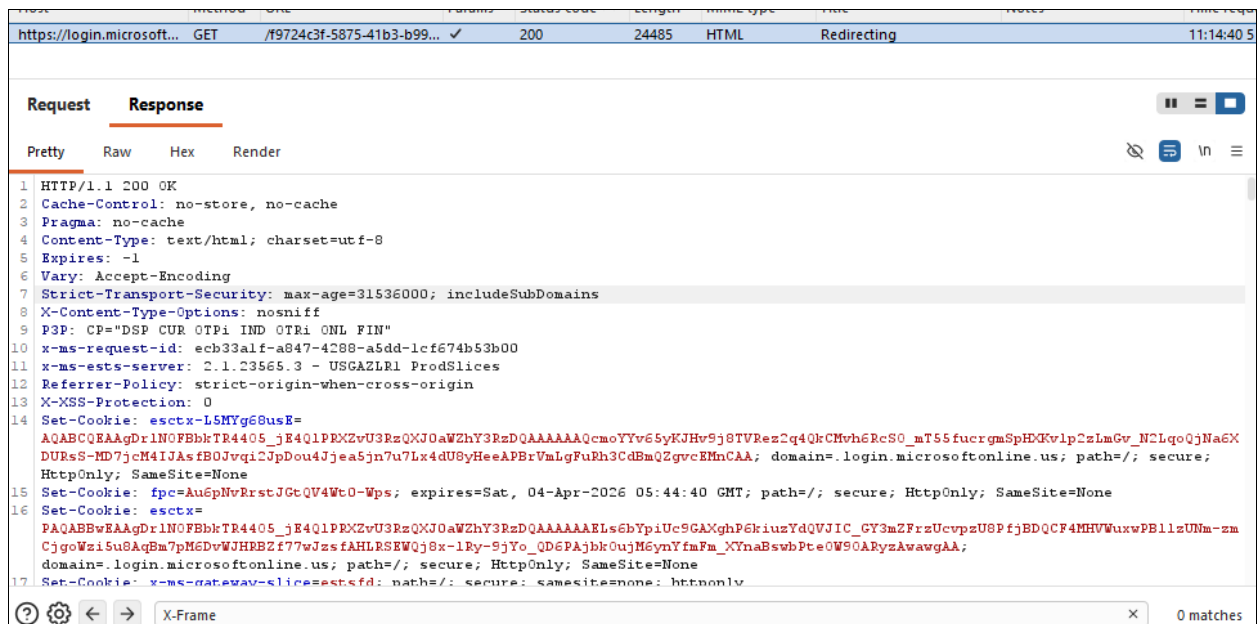


Figure 1

Remediation:

Enable X-FRAME-OPTIONS protection. X-Frame-Options Header Types

There are three possible values for the X-Frame-Options headers:

DENY, which prevents any domain from framing the content.

SAMEORIGIN, which only allows the current site to frame the content.

ALLOW-FROM uri, which permits the specified 'uri' to frame this page (NOTE: Not all browsers support this option).

Closing/Downgrading Justification:

Finding 6 : BREACH Vulnerability

Informational

Dependency: Microsoft

Status: Open

Description:

BREACH (a backronym: Browser Reconnaissance and Exfiltration via Adaptive Compression of Hypertext) is a security exploit against HTTPS when using HTTP compression. BREACH is built based on the CRIME security exploit.

Note: *The original severity of the finding is Low. However, it is being rated as Informational in this report. The finding is tracked in PPA-332020*

Affected Systems & Locations:

<https://login.microsoftonline.com>

Reproduction Steps:

1. Run OpenSSL and check for Breach Vulnerability.
2. It is observed that compressed response is received, indicating that the domain may be vulnerable to BREACH.



Figure 1

Remediation:

BREACH exploits the compression in the underlying HTTP protocol. Therefore, turning off TLS compression makes no difference to BREACH, which can still perform a chosen-plaintext attack against the HTTP payload. As a result, clients and servers are either forced to disable HTTP compression completely (thus reducing performance), or to adopt workarounds to try to foil BREACH in individual attack scenarios, such as using cross-site request forgery (CSRF) protection. Another suggested

Closing/Downgrading Justification:

Finding 7: Concurrent User Session

Informational

Dependency: Application

Status: Open

Description: During the Single Sign-On (SSO) configuration review and testing of the application authentication flow, it was observed that the application allows multiple concurrent sessions for the same user account from different browsers and client IP addresses. During testing, the same user account was able to authenticate successfully from multiple browser sessions simultaneously without invalidating the previously established session. Both sessions remained active and were able to access the application at the same time.

Allowing concurrent sessions is typically a design decision depending on the organization's security policy. However, in certain environments where sensitive data is handled, limiting concurrent sessions or notifying users of simultaneous logins can help reduce risks associated with session misuse, credentials sharing, or unauthorized access.

If organizations require stricter session management controls, mechanisms should be implemented to detect and manage concurrent sessions appropriately.

Affected Systems & Locations:

<https://shielddev.servicenowservices.com/navpage.do>

Reproduction Steps:

Open the application login page and authenticate using valid user credentials through the configured SSO provider (Azure).

Once authentication is successful, access the application dashboard and verify that the user session is active.

Open a new browser session and login in again using the same user account through the SSO authentication flow.

After the second authentication is completed, verify that both browser sessions remain active.

Confirm that both sessions can access the application simultaneously without any session termination or warning.

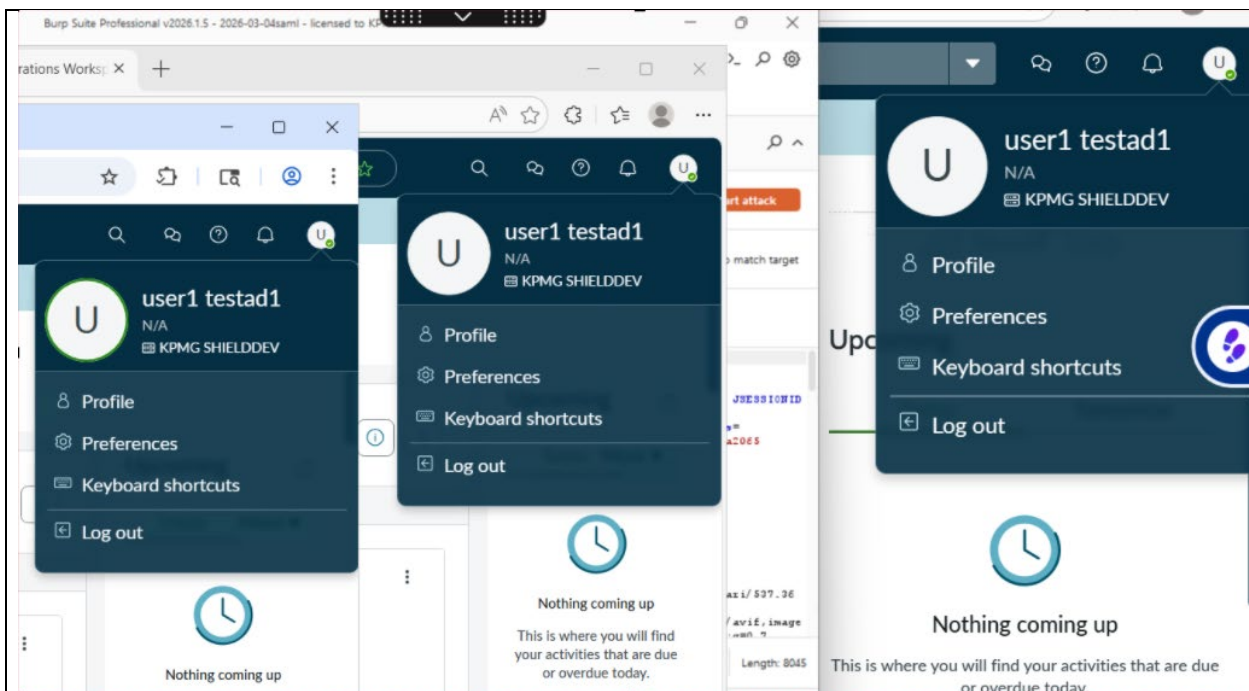


Figure 1

Remediation:

It is recommended that web applications implement enhanced session management capabilities where appropriate. These may include:

- Providing users with visibility into their active sessions and login activity.
- Implementing controls to limit the number of concurrent sessions allowed per user account.
- Notifying users when multiple sessions are active simultaneously.
- Providing functionality to remotely terminate active sessions.
- Logging session activity such as login time, client IP address, device information, and session duration for monitoring purposes.

Also consider implementing configurable session management policies based on their risk tolerance and security requirements.

Closing/Downgrading Justification:

Finding 8: Sensitive Information Disclosure

Informational

Dependency: Application

Status: Open

Instance 1:

Description: During testing, it was observed that the application discloses backend server information in the HTTP response headers. Specifically, the response to the /sp/metadata endpoint includes the follow header:

Server: snow_adc

This header reveals information about the server infrastructure handling the request. Exposing server technology details can assist attackers in performing reconnaissance and identifying the underlying platform used by the application.

Such information can allow attackers to:

Fingerprint the application infrastructure.

Identify platform-specific vulnerabilities.

Tailor attacks against known weakness of the disclosed technology.

Although this issue does not directly expose sensitive data or allow immediate exploitation, minimizing unnecessary information disclosure is considered a security best practice.

Affected Systems & Locations:

<https://shielddev.servicenowservices.com/navpage.do>

Reproduction Steps:

1. Send an HTTP request to the following endpoint:
2. Inspect the HTTP response headers.
3. Observe that the response includes the following header revealing the server technology:

The response returns HTTP status 200 ok along with the server identification header.

Screenshots:



```
POST /sp/metadata HTTP/1.1
Host: shielddev.servicenowservices.com
Cookie: glide_sso_id=3d67746693e2b250701bf
```

Figure 1

Figure 2

It is recommended to suppress or modify server identification headers to prevent unnecessary disclosure of backend infrastructure information.

- 1 Removing or masking the Server header in HTTP responses.
- 2 Configuring the web server or reverse proxy to return generic server information.
- 3 Implementing header filtering at the load balancer or application level.
- 4 Remove/mask sensitive information like API key

Reducing exposed infrastructure details helps limits reconnaissance opportunities for attackers.

Closing/Downgrading Justification:

Finding 9: CBC-mode Encryption Cipher Suites Supported in TLS

Informational

Dependency: Application

Status: Open

Description: During the TLS configuration assessment of the application endpoint, it was observed that the server supports cipher suites utilizing Cipher Block Chaining (CBC) mode encryption.

CBC-mode cipher suites have historically been associated with cryptographic weakness such as the Lucky 13 timing attack, which theoretically allows attackers to recover plain text from encrypted TLS communications under specific circumstances.

Although modern TLS implementation typically includes mitigations against such attacks, the continued support of CBC-mode cipher suites increases the potential attack surface and allows the use of legacy encryption mechanisms.

Additionally, several cipher suites utilizing RSA key exchange are supported. These cipher suites do not provide Forward Secrecy, meaning that if the server's private key is compromised in the future, previously recorded encrypted sessions could potentially be decrypted.

While the server also supports modern and secure cipher suites using AES-GCM, the presence of CBC-based and RSA key exchange cipher suites indicates that the TLS configuration allows legacy cryptographic options.

Industry security guidelines recommend disabling legacy cipher suites and prioritizing modern authenticated encryption algorithms.

Affected Systems & Locations:

<https://shielddev.servicenowservices.com/navpage.do>

Reproduction Steps:

Navigate to SSL labs TLS testing tool or equivalent TLS scanner. Scan the endpoint

Review the TLS configuration section of the scan results.

Observe that the server supports CBC-mode cipher suites including:

TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (0xc02f)	ECDH x25519	128
(eq. 3072 bits RSA) FS		
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (0xc030)	ECDH x25519	256
(eq. 3072 bits RSA) FS		
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (0xc027)	ECDH x25519	128
(eq. 3072 bits RSA) FS WEAK		
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (0xc013)	ECDH x25519 (eq.	128
3072 bits RSA) FS WEAK		

TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (0xc028)	ECDH x25519	256
(eq. 3072 bits RSA)	FS	WEAK
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (0xc014)	ECDH x25519 (eq.	256
3072 bits RSA)	FS	WEAK
TLS_RSA_WITH_AES_128_GCM_SHA256 (0x9c)		128
TLS_RSA_WITH_AES_256_GCM_SHA384 (0x9d)		256
TLS_RSA_WITH_AES_128_CBC_SHA256 (0x3c)		128
TLS_RSA_WITH_AES_256_CBC_SHA256 (0x3d)		256
TLS_RSA_WITH_AES_128_CBC_SHA (0x2f)		128
TLS_RSA_WITH_AES_256_CBC_SHA (0x35)		WEAK

The scan also identifies several cipher suites marked as Weak, indicating legacy cryptographic support.

Configuration			
 Protocols			
TLS 1.3			No
TLS 1.2			Yes
TLS 1.1			No
TLS 1.0			No
SSL 3			No
SSL 2			No
 Cipher Suites			
# TLS 1.2 (suites in server-preferred order)			
TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (0xc02f)	ECDH x25519 (eq. 3072 bits RSA)	FS	128
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (0xc030)	ECDH x25519 (eq. 3072 bits RSA)	FS	256
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (0xc027)	ECDH x25519 (eq. 3072 bits RSA)	FS	WEAK 128
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (0xc013)	ECDH x25519 (eq. 3072 bits RSA)	FS	WEAK 128
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (0xc028)	ECDH x25519 (eq. 3072 bits RSA)	FS	WEAK 256
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (0xc014)	ECDH x25519 (eq. 3072 bits RSA)	FS	WEAK 256
TLS_RSA_WITH_AES_128_GCM_SHA256 (0x9c)			WEAK 128
TLS_RSA_WITH_AES_256_GCM_SHA384 (0x9d)			WEAK 256
TLS_RSA_WITH_AES_128_CBC_SHA256 (0x3c)			WEAK 128
TLS_RSA_WITH_AES_256_CBC_SHA256 (0x3d)			WEAK 256
TLS_RSA_WITH_AES_128_CBC_SHA (0x2f)			WEAK 128
TLS_RSA_WITH_AES_256_CBC_SHA (0x35)			WEAK 256

Figure 1

Remediation:

It is recommended to update the TLS configuration to disable legacy CBC-mode and RSA key exchange cipher suites and prioritize modern authenticated encryption cipher suites.

Disable cipher suits utilizing CBC mode encryption where compatibility allows.

Disable RSA key exchange cipher suites to ensure Forward Secrecy.

Enable TLS 1.3 were supported by the application infrastructure.

These changes will strengthen the overall TLS security posture of the application.

Closing/Downgrading Justification:

Appendix

Risk Rating Criteria

Overall Risk Rating Matrix					
Likelihood	Impact				
	Negligible	Minor	Moderate	Significant	Severe
Very High	Low	Medium	High	High	Very High
High	Low	Medium	Medium	High	High
Medium	Low	Low	Medium	Medium	High
Low	Low	Low	Low	Medium	Medium
Very Low	Informational	Low	Low	Low	Low

Likelihood * Impact Risk Rating	
Risk Rating	Value
Very High	25
High	15-20
Medium	7-14
Low	1-6
Informational	1

Risk Rating is determined by multiplying Impact * Likelihood

Examples:

Likelihood Low (2) * Impact Moderate (3) = 6 (Low)

Likelihood High (4) * Impact Moderate (3) = 12 (Medium)

Likelihood Very High (5) * Impact Severe (5) = 25 (Very High)

Impact Rating Guidance	
Severe	Typically reserved for compromise (e.g. data exfiltration, ransomware) of DC3-type datasets, passwords/credentials with access to significant resources, or complete takeover of a system which has significant impacts to KPMG for lateral-based movement/attacks and disruption to the business (e.g. RP0/RP1-rated systems such as Active Directory).
Significant	Typically reserved for compromise (e.g. data exfiltration, ransomware) of DC3-type datasets, passwords/credentials with access to significant resources, or complete takeover of a system which has significant impacts to KPMG for lateral-based movement/attacks and disruption to the business.
Moderate	Typically reserved for compromise (e.g. data exfiltration, ransomware) of DC2-type datasets or partial takeover of a system which has moderate impacts to the business (e.g. RP2-rated systems such as a Business Application).
Minor	Typically reserved for compromise (e.g. data exfiltration, ransomware) of low-risk datasets such as DC1 or partial takeover of a system which has low impact of disruption to the business (e.g. RP3/4-rated systems).
Negligible	Reserved to document findings which have no material impact to KPMG or the Business.

Terminology

Depending on likelihood and impact, the findings will be assigned to one of the following risk ratings:

Very High

Very high risk findings represent a severe weakness that can be easily exploited by an adversary, leading to a direct and immediate impact on the business. This could include a full system compromise, significant data exfiltration, or a widespread denial-of-service condition. Such vulnerabilities pose the highest level of security risk.

Immediate action is required. For systems not yet in production, remediation must be completed before the "go-live" date. For production systems, remediation must be completed within five (5) days of the preliminary report date.

High

A high risk finding indicates a significant weakness that, if exploited, could result in substantial damage to business assets or reputation. Exploitation may require more specific conditions or attacker skill than a critical finding but still presents a high degree of security risk.

For systems not yet in production, remediation must be completed before the "go-live" date. For production systems, remediation must be completed within thirty (30) days of the preliminary report date.

Medium

A medium risk finding points to a moderate security weakness. While it may not lead to a full system compromise on its own, it could be leveraged by an attacker in conjunction with other vulnerabilities to achieve a greater impact or could result in minor data leakage or service degradation.

For systems not yet in production, remediation should be completed before the "go-live" date. For production systems, remediation must be completed within sixty (60) days of the preliminary report date.

Low

A low risk finding identifies a minor security weakness that has a limited potential for impact. Exploiting such a flaw is often difficult or would result in minimal damage. These findings typically represent a minor security risk but should be addressed to maintain a strong security posture.

Remediation for low-risk findings is recommended to be included in the next scheduled product update or maintenance cycle.

Informational

An informational finding is an observation that does not represent an immediately exploitable vulnerability but highlights a deviation from security best practices, a configuration weakness, or unusual system behavior that could pose a risk in the future.

No formal Remediation SLA is defined for informational findings. These are provided for consideration to improve overall security hygiene.

Methodology

Our security assessment follows a structured methodology designed to provide comprehensive and rigorous testing, from initial discovery to final reporting.

Reconnaissance and Discovery

The engagement begins with defining the external attack surface. We conduct reconnaissance to map the client's internet-facing infrastructure, using a combination of public sources and specialized tools. The objective is to identify all associated IP blocks, hostnames, domains, and subdomains. This process reveals the full scope of potential targets and informs the subsequent stages of the assessment.

Threat Modeling and Analysis

Following discovery, each in-scope application is analyzed to create a comprehensive threat model. We map critical information flows, business logic, user roles, architectural dependencies (e.g., web servers, APIs, databases), and third-party components. This analysis allows us to identify likely threat actors, define key attack vectors, and prioritize testing efforts based on the application's unique risk profile.

Application Enumeration and Profiling

With the attack surface defined, we actively enumerate the target applications to build a detailed service and functionality profile. Using a variety of tools and manual techniques, we gather in-depth information about the application's structure, technologies, and exposed resources. This intelligence gathering is crucial for identifying specific modules, functions, and configurations that will be targeted during vulnerability testing.

Vulnerability and Security Control Analysis

This is the core testing stage where we execute a comprehensive vulnerability assessment to identify security weaknesses. Our methodology is guided by industry-standard frameworks, including the OWASP Top 10, CWE Top 25, and MITRE ATT&CK®. We employ a combination of automated scanning and rigorous manual testing to evaluate the effectiveness of existing security controls across several key categories:

- Information Gathering
- Configuration and Deployment Management
- Authentication and Authorization
- Session Management
- Input Validation and Sanitization
- Cryptography and Data Protection

This hybrid approach ensures we identify both known vulnerabilities and complex, logic-based flaws that automated tools often miss.

Exploitation and Impact Validation

This activity validates the real-world impact of vulnerabilities identified during the assessment. We perform controlled exploitation of discovered weaknesses to determine the severity and potential business impact. By simulating adversarial tactics, we demonstrate how an attacker could compromise the application, escalate privileges, or access sensitive data, providing clear evidence of the risk.

Mitigation and Remediation Strategy

Based on the findings from the engagement, we develop a comprehensive mitigation plan. This includes providing tactical recommendations for addressing each specific vulnerability, as well as strategic guidance on secure development practices to enhance the overall security posture of the application.

Reporting

The final activity involves documenting all observations, findings, and recommendations in a formal report. Each vulnerability is assigned a risk rating based on the Common Vulnerability Scoring System (CVSS v3.1) and mapped to relevant CWE identifiers. The report delivers a clear, actionable summary for stakeholders and detailed technical analysis for engineering teams.

DSG Disclaimer Notice

Cybersecurity threats are continually changing, with new vulnerabilities discovered on a daily basis, and no application can ever be 100% secure no matter how much security testing is conducted. This report cannot and does not protect against personal or business loss as the result of use of the applications or systems described. DSG offers no warranties, representations or legal certifications concerning the applications or systems it tests.

All software includes defects: nothing in this document is intended to represent or warrant that security testing was complete and without error, nor does this document represent or warrant that the application tested is suitable to task, free of other defects than reported, fully compliant with any industry standards, or fully compatible with any operating system, hardware, or other application. By using this reported information, you agree that DSG shall be held harmless in any event.

Non-Production and Production Testing Advisory

It is important for the customer to understand that the engagement testing in non-production environments such as UAT (User Acceptance Testing) or QC (Quality Control) represents what is found only in such environments. If there are inaccuracies, omissions, or changes made during or after the testing engagement; this may impact findings visibility and ultimately the accuracy of this report. It is equally important to note that UAT and QC environments should ultimately mimic the production environment. DSG pen testers, unless at the request of the customer, do not typically perform testing within a production environment for general stability and safety concerns. If production testing is a requirement by the SRM (Security Relationship Manager), please create a separate PTI (Penetration Testing Intake) form for as such and notify the DSG pen testers.

Modifications during Testing Engagements

If the customer performs any modifications or changes to the testing environment during an engagement, this may adversely impact the accuracy of the report and findings. Customers should be prepared to freeze changes where possible. If it is not possible, please notify the DSG pen testers of the intended change, time of change, and to which assets it will affect.

Scope of Findings Disclaimer

This report provides representative examples of vulnerabilities identified during the assessment. These examples should not be considered exhaustive. We recommend implementing a comprehensive, systemic remediation approach to address all potential instances of the identified issues, rather than limiting corrective actions to only the specific examples outlined in this report.

Contact us

Digital Security Group Adversarial Testing

US-DLBPGAdversarialTestingAll@kpmg.com

Learn about us:



kpmg.com